ملاحظات الدرس — لك

قائمة OWASP لأخطر عشرة مخاطر في تطبيقات النماذج اللغوية

أمن الذكاء الاصطناعي، الجامعة، الدرس ٢

المدة
٢٠ دقيقة

المواد
المخاطر العشرة (في الشرائح)، تطبيق مبني على نموذج لغوي تبنيه، أو تصميم على الورق، هاتف أو حاسوب لاختبار الترميز، إن توفّر

أهداف التعلّم

- تسمّي مخاطر OWASP العشرة لتطبيقات النماذج اللغوية، مع مثال لكلٍّ منها.
- تعامل مخرجات النموذج بوصفها غير موثوقة: ترمّزها قبل استخدامها.
- تُبقي الأسرار وقواعد الوصول خارج التعليمات.

النشاط: مراجعة المخاطر العشرة

١. الفرز (٥ دقائق): اكتب المخاطر العشرة على بطاقات (الرقم والاسم). ومع زميل، صنّفاها إلى ما يدخل، وما يخرج، والنظام حول النموذج، ثم قارنا بالشريحة.
٢. المراجعة (٨ دقائق): لتطبيق تبنيه، أو تصميم من خيالك، اكتب سطرًا لكل خطر: هل يمكن أن يقع هنا، وما الدليل؟
٣. الإصلاح (٥ دقائق): اختر أكبر ثلاثة مخاطر، واكتب لكلٍّ منها إجراءً وقائيًا يغيّر التصميم (ترميز المخرجات، أو إزالة أداة، أو وضع حدّ)، لا التعليمات وحدها.
٤. الاختبار (دقيقتان): لإجراء وقائي واحد، اكتب الاختبار الذي يُثبت أنه يعمل، مثل ترميز خمسة ردود مخادعة.

راجع تطبيقك أنت أو تصميمًا من خيالك. ولا تختبر تطبيقًا حيًّا دون إذن مكتوب أبدًا.

للنقاش

- لماذا يُعدّ ردّ النموذج غير موثوق، مع أن تطبيقك هو من طلبه؟
- أيّ خطر أسهل إصلاحًا بالتصميم؟
- لماذا لا تحمي عبارة «لا تكشف هذا أبدًا» السرّ؟

تحقّق من نفسك

- اكتب خطرًا واحدًا من العشرة ينطبق على تطبيق تستخدمه، وإجراءه الوقائي.

جرّبها هذا الأسبوع

خذ تطبيقًا مبنيًا على نموذج لغوي تستخدمه أو تبنيه، وامضِ في المخاطر العشرة: سطر لكلٍّ منها، هل يمكن أن يقع هنا وما الذي يمنعه. ثم أصلح الثلاثة التي تستطيع إصلاحها أسرع.

ورقة عمل

قائمة OWASP لأخطر عشرة مخاطر في تطبيقات النماذج اللغوية

أمن الذكاء الاصطناعي، الجامعة، الدرس ٢

الاسم _____ الفصل _____ التاريخ _____

١ **يستطيع مساعد للمذاكرة حذف الملفات، مع أن مهمته قراءتها فقط. أيّ خطر هذا؟**

◯ المعلومات المضلّلة ◯ الاستهلاك غير المحدود ◯ الصلاحيات المفرطة

٢ **صِل كل خطر من قائمة OWASP بمثال عليه.**

LLM01 حقن الأوامر	يقتبس من مقال طالب آخر
LLM02 كشف المعلومات الحساسة	طلبات مستخدم واحد التي لا تنتهي ترفع الفاتورة كثيرًا
LLM06 الصلاحيات المفرطة	صفحة ويب يلخّصها تطلب منه تجاهل قواعده
LLM10 الاستهلاك غير المحدود	يستطيع حذف الملفات مع أنه يحتاج إلى قراءتها فقط

٣ **تعرض صفحة المقرر ردود روبوت الدردشة. أكمل escape_html(t) لتتحوّل المحارف ' " < > & إلى < > " '. وانتبه إلى الترتيب: البداية تنسى علامة &.**

```
def escape_html(t):
    t = t.replace("<", "&lt;")
    t = t.replace(">", "&gt;")
    return t

reply = 'Mark: <b>9</b> & "well done"'
print(escape_html(reply))
```

اكتب برنامجك:

٤ **ماذا يطبع هذا البرنامج؟**

```
def bad(t):
    t = t.replace("<", "&lt;")
    return t.replace("&", "&amp;")

print(bad("<b>"))
```

◯ <b> ◯ <b> ◯ <b>

٥ **أيّ مما يلي يحمي سرًّا من تسريب تعليمات النظام؟ اختر كل ما ينطبق.**

☐ أن تقول للنموذج «لا تكشف هذا أبدًا» ☐ تقرير من يرى ماذا في الكود، لا في التعليمات

☐ إبقاء مفاتيح الواجهات البرمجية في كود التطبيق أو خزنته، لا في التعليمات أبدًا ☐ إعطاء النموذج بيانات هذا المستخدم وحدها

☐ كتابة السرّ بلغة أخرى

✎ **اختر تطبيقًا مبنيًا على نموذج لغوي تستخدمه. أيّ المخاطر العشرة يقلقك أكثر فيه، وماذا ستفحص أولًا؟**

تحقّق من إجاباتك

قائمة OWASP لأخطر عشرة مخاطر في تطبيقات النماذج اللغوية

أمن الذكاء الاصطناعي، الجامعة، الدرس ٢

١ **الصلاحيات المفرطة**

امتلاك أدوات أو صلاحيات أكثر مما تحتاج إليه المهمة هو «الصلاحيات المفرطة».

٢

LLM01 حقن الأوامر — صفحة ويب يلخّصها تطلب منه تجاهل قواعده

LLM02 كشف المعلومات الحساسة — يقتبس من مقال طالب آخر

LLM06 الصلاحيات المفرطة — يستطيع حذف الملفات مع أنه يحتاج إلى قراءتها فقط

LLM10 الاستهلاك غير المحدود — طلبات مستخدم واحد التي لا تنتهي ترفع الفاتورة كثيرًا

لكل خطر شكل معتاد: أوامر مخبّأة في المدخلات، وبيانات خاصة في المخرجات، وقدرات لا تحتاج إليها المهمة، واستخدام بلا حدود.

٣

```
def escape_html(t):
    t = t.replace("&", "&amp;")
    t = t.replace("<", "&lt;")
    t = t.replace(">", "&gt;")
    t = t.replace('"', "&quot;")
    return t.replace("'", "&#x27;")

reply = 'Mark: <b>9</b> & "well done"'
print(escape_html(reply))
```

يحوّل الترميز ما في الرد من وسوم إلى نص يعرضه المتصفح بدل أن يشغّله.

٤ **<b>**

تصبح < هي <، ثم يحوّل استبدال & تلك العلامة الجديدة إلى &، فيصير الناتج <b>.

٥ **إبقاء مفاتيح الواجهات البرمجية في كود التطبيق أو خزنته، لا في التعليمات أبدًا، تقرير من يرى ماذا في الكود، لا في التعليمات، إعطاء النموذج بيانات هذا المستخدم وحدها**

افترض أن تعليمات النظام ستُقرأ. فالأسرار وقواعد الوصول مكانها الكود، ويجب ألا يحمل النموذج إلا بيانات يحقّ لهذا المستخدم رؤيتها.